

개인정보 보호법 해설

1 개인정보의 개념 및 원칙

□ 개인정보의 개념·범위(개인정보 보호법 제2조)

○ (개인정보의 정의) “개인정보”란

- 살아있는① 개인②에 관한 정보③로서

성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는④ 정보

(해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합⑤하여 알아볼 수 있는 정보)

- 가명처리⑥함으로써 추가 정보의 사용·결합 없이는 특정 개인을 알아볼 수 없는 정보(가명정보) ※ 가명정보도 개인정보에 포함

[표 1-1] 개인정보의 구성요소

용어		설명
①	살아있는	생존하는 자에 대한 정보만 보호의 대상이 되며 사자(死者)의 정보는 제외되나, 사자(死者)의 정보가 다른 정보와 쉽게 결합하여 생존하는 자의 개인정보에 해당될 때는 보호의 대상이 될 수 있음
②	개인	생존하는 사람에 해당(법인이나 단체는 포함하지 않음)
③	정보	정보의 종류·형태를 제한하지 않음(문자·음성·부호·영상 등)
④	알아볼 수 있는	특정 개인을 다른 사람과 구분하여 알아 볼 수 있는 정보
⑤	다른 정보와 쉽게 결합	합리적인 비용과 시간을 통해 결합이 가능한 경우로서 일률적으로 판단할 수는 없으며, 다른 개인정보의 종류, 업무의 성격 등 상황에 따라 판단
⑥	가명처리	개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가 정보가 없이는 특정 개인을 알아볼 수 없도록 처리하는 것

[표 1-2] 개인정보가 될 수 있는 사항

유형	개인정보 항목
일반정보	이름, 주민등록번호, 주소, 전화번호, 생년월일, 출생지, 본적지, 성별, 국적
가족정보	가족 구성원들의 이름, 출생지, 생년월일, 주민등록번호, 직업, 전화번호
교육 및 훈련정보	학교 출석사항, 최종학력, 학교성적, 기술자격증 및 전문 면허증, 이수한 훈련 프로그램, 동아리활동, 상벌사항
병역정보	군번 및 계급, 제대유형, 주특기, 근무부대
부동산정보	소유주택, 토지, 상점 및 건물 등
소득정보	현재 봉급액, 봉급경력, 보너스 및 수수료, 기타소득의 원천, 사업소득
기타 수익정보	보험(건강, 생명 등) 가입현황, 투자프로그램, 퇴직프로그램, 휴가, 병가 등
신용정보	융자 및 납입현황, 저당, 신용카드, 임금압류 통보에 대한 기록 등
고용정보	현재의 고용주, 회사주소, 훈련기록, 직무수행평가기록, 근태기록, 상벌기록, 성격 테스트결과, 직무태도 등
법적정보	전과기록, 범칙금 및 과태료 부과, 파산 및 담보기록, 구속기록, 이혼기록, 납세기록 등
의료정보	가족병력기록, 과거의 의료기록, 정신질환기록, 신체장애, 혈액형, IQ, 약물테스트 등 각종 신체테스트 정보
조직정보	종교단체 가입, 클럽회원
통신정보	전자우편(E-mail), 전화통화 내용
위치정보	GPS나 휴대폰에 의한 개인의 위치정보
신체정보	지문, 홍채, DNA, 신장, 가슴둘레 등
습관 및 취미정보	선호하는 스포츠 및 오락, 여가활동, 비디오 대여기록, 독서성향 등

□ 개인정보처리자 · 보호책임자 · 취급자의 개념

○ (개인정보처리자) 업무를 목적으로 개인정보파일을 운용하기 위해 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등(법 제2조 및 시행령 제2조)

※ 공공기관

- 「초·중등교육법」, 「고등교육법」, 그 밖의 다른 법률에 따라 설치된 각급 학교
- 헌법기관(국회, 법원, 헌법재판소 등), 중앙행정기관 및 그 소속기관, 지방자치단체, 국가인권위원회, 「공공기관의 운영에 관한 법률」에 따른 공공기관, 지방공사 및 공단, 특수법인

○ **(개인정보 보호책임자)** 각급 학교 등 개인정보처리자가 지정하는 사람으로 개인정보의 처리에 관한 업무를 총괄해서 책임을 지는 자(법 제31조)

- ▶ 초·중·고: **교장** (유치원은 원장)
- ▶ 시·도교육청: 3급 이상 공무원 또는 그에 상응하는 공무원
- ▶ 교육지원청: 4급 이상 공무원 또는 그에 상응하는 공무원
- ▶ 그 외 기관: 개인정보 처리 관련 업무를 담당하는 부서의 장

개인정보 보호책임자(CPO)의 수행 업무

- ① 내부 관리계획 및 개인정보 처리방침 등 개인정보 보호 관련 지침 수립·승인·시행
- ② 각종 개인정보 처리 실태 조사 및 개선
- ③ 개인정보 처리와 관련한 불만의 처리 및 피해 구제
- ④ 교직원 및 개인정보취급자 등에 대한 개인정보 보호 교육계획의 수립·시행
- ⑤ 개인정보파일의 보호 및 관리·감독
- ⑥ 개인정보 보호 관련 자료의 관리
- ⑦ 개인정보파일의 보유기간 산정
- ⑧ 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기
- ⑨ 가명정보 처리에 관한 사항
- ⑩ 기타 개인정보 보호에 필요한 사항

○ **(개인정보취급자)** 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 업무를 담당하는 자로서 직접 개인정보에 관한 업무를 담당하는 자와 그 밖에 업무상 필요에 의해 개인정보에 접근하여 처리하는 모든 자를 말함(법 제28조)

※ 파견근로자, 시간제근로자, 임시강사 등도 개인정보를 처리하는 경우 개인정보 취급자에 해당

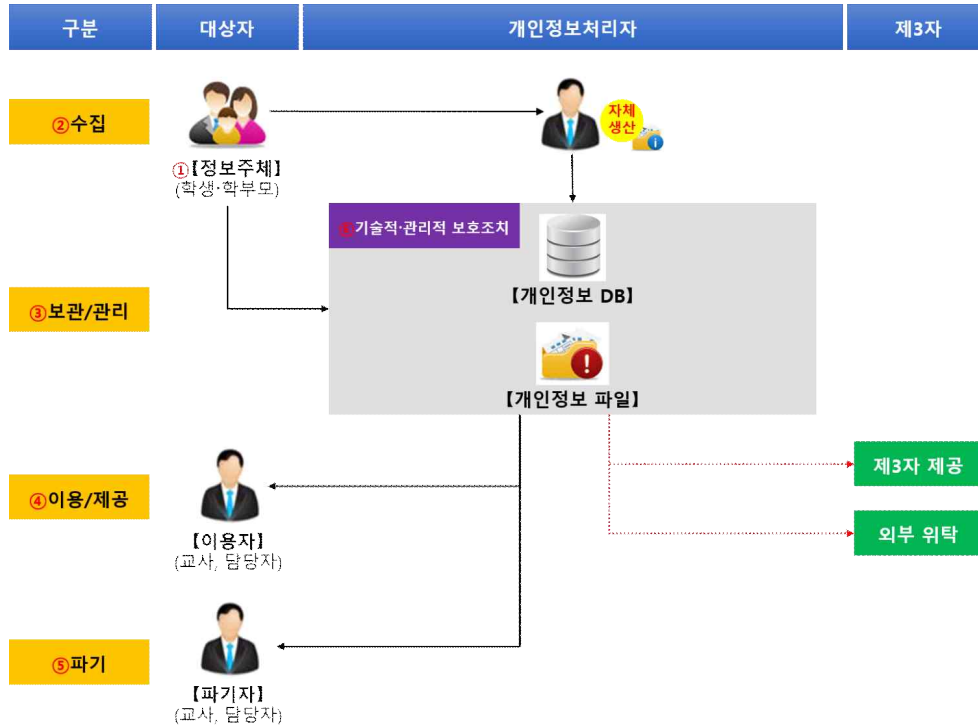
□ 개인정보 보호의 원칙(법 제3조)

- ① 명확한 목적으로 적법하고 정당하게 최소 수집
- ② 처리 목적 내에서 적합하게 처리, 목적 외 활용 금지
- ③ 처리 목적 내에서 정확성·완전성·최신성 보장
- ④ 정보주체의 권리침해 가능성 등을 고려하여 안전하게 관리
- ⑤ 개인정보 처리방침 등 개인정보의 처리에 관한 사항 공개 및 열람청구권 등 정보주체의 권리보장
- ⑥ 정보주체의 사생활 침해 최소화 방법으로 처리
- ⑦ 익명처리가 가능한 경우에는 익명으로, 익명처리로 목적을 달성할 수 없는 경우에는 가명으로 처리
- ⑧ 개인정보처리자의 책임과 의무 준수, 정보주체의 신뢰성 확보

2 개인정보의 단계별 처리 과정 및 개인정보 처리 제한

□ 개인정보 단계별 처리 과정(생명주기, Life-Cycle)

○ 개인정보는 수집, 저장·관리, 이용·제공, 파기의 절차와 단계로 이루어짐



[표 1-3] 개인정보의 구성요소

용어		설명
①	정보주체	개인정보의 소유자 또는 법적 대리인
②	수집	정보주체의 동의를 받은 경우, 법률에 특별한 규정이 있거나 법령상 의무 준수를 위해 필요한 경우 등에만 수집 가능 ※ 법률에 특별한 규정의 예시 · 학생의 성적, 학적, 생활기록부(초·중등교육법 제25조) · 건강기록부(학교보건법 제7조의3)
③	보관·관리	접근통제 및 권한 제한, 암호화 조치, 보안프로그램 적용 등 안전관리조치
④	이용·제공	수집 시 명시한 목적 내에서 이용(목적 외 이용 시 추가 동의) 정보주체 동의 없는 개인정보의 제공 및 공유 금지
⑤	파기	보유기간 경과 및 처리목적 달성 시 복구 또는 재생되지 않도록 지체 없이 파기
⑥	관리적·기술적 보호조치	개인정보를 안전하게 보호하기 위하여 법령상 규정에 따른 관리적(내부 관리계획, 정책 등), 기술적(암호화, 접근통제 등) 보호조치

□ 개인정보의 수집·이용(법 제15조)

○ 제한 사항 및 고지 의무

- 필요한 최소한의 개인정보 수집, 미 동의를 이유로 재화나 서비스 제공 거부 금지
- 수집 및 이용 목적의 범위를 초과하여 이용 제한
- 만 14세 미만 아동의 경우 법정대리인의 동의를 받아야 함
- 정보주체 이외로부터 수집한 경우 정보주체의 요구 시 출처 등 고지 의무

○ 개인정보의 수집·이용 기준(법 제15조제1항)

1. 정보주체의 동의를 받은 경우
2. 법률에 특별한 규정, 법령상 의무 준수를 위해 불가피한 경우
3. 법령 등에서 정한 공공기관의 소관업무 수행을 위해 불가피한 경우
4. 정보주체와의 계약체결·이행을 위해 불가피한 경우
5. 명백히 정보주체 또는 제3자의 생명, 신체, 재산의 이익 보호를 위해 필요한 경우
6. 개인정보처리자의 정당한 이익 달성을 위해 필요한 경우로서, 명백하게 정보주체의 권리보다 우선하는 경우. 이 경우 개인정보처리자의 정당한 이익과 상당한 관련이 있고 합리적인 범위를 초과하지 아니하는 경우에 한함
7. 공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우

○ 정보주체의 동의 획득 시 필수 고지사항(법 제15조제2항)

- ① 수집·이용 목적 ② 수집 항목
- ③ 보유·이용 기간 ④ 동의 거부 권리 및 동의 거부 시 불이익 내용

□ 개인정보의 제공(목적 내, 법 제17조)

- (개인정보의 제공) 개인정보처리자가 수집한 개인정보를 제3자(정보주체를 제외한 그 밖의 모든 자)에게 제공하고자 할 때에는 개인정보를 수집한 목적 범위 내에서 제공할 수 있으며 목적 범위를 벗어날 경우 정보주체의 추가 동의 필요

○ 개인정보의 수집 목적 내 제3자 제공 기준(법 제17조제1항)

1. 정보주체의 동의를 받은 경우
2. 법률의 특별한 규정, 법령상 의무 준수를 위해 불가피한 경우
3. 공공기관이 법령 등에서 정한 소관업무를 위해 불가피한 경우
4. 명백히 정보주체 등의 급박한 생명, 신체, 재산의 이익을 위해 필요한 경우로서 정보주체의 사전 동의를 받을 수 없는 경우
5. 공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우

○ 정보주체의 동의 획득 시 필수 고지사항(법 제17조제2항/제18조제3항)

- ① 제공받는 자의 성명(단체명) 및 연락처
- ② 제공받는 자의 개인정보 이용 목적
- ③ 제공하는 개인정보의 항목
- ④ 제공받는 자의 개인정보 보유·이용 기간
- ⑤ 동의 거부 권리 및 동의 거부 시 불이익 내용

□ 개인정보의 목적 외 이용·제공(법 제18조)

○ 개인정보의 목적 외 이용 및 목적 외 제3자 제공은 원칙적으로 처리 금지

○ 목적 외 이용 및 목적 외 제3자 제공 허용기준(법 제18조제2항)

정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 있을 때를 제외하고는 다음 각 호에 따라 목적 외 이용 및 목적 외 제3자 제공이 가능

1. 정보주체의 별도의 동의를 받은 경우

2. 다른 법률에 특별한 규정이 있는 경우

* 시행령, 시행규칙에만 규정이 있는 경우에는 허용되지 않음. 법률에 위임근거가 있고 이에 따라 시행령, 시행규칙에 규정이 있는 경우 허용

3. 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익에 필요한 경우

4. 개인정보를 목적 외로 이용하거나 이를 제3자에게 제공하지 않으면 다른 법률에서 정하는 소관 업무 수행 불가한 경우로 보호위원회의 심의·의결을 거친 경우

5. 조약, 국제협정 이행을 위해 외국정부 등 제공에 필요한 경우

6. 범죄의 수사와 공소의 제기 및 유지를 위하여 필요한 경우

7. 법원의 재판업무 수행을 위하여 필요한 경우

8. 형(刑) 및 감호, 보호처분의 집행을 위하여 필요한 경우

9. 공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우

○ (목적 외 이용·제공 시 의무 사항)

- ① 개인정보를 제공받는 자에게 이용 목적, 이용 방법, 그 밖에 필요한 사항에 대하여 제한을 하거나, 개인정보의 안전성 확보를 위하여 필요한 조치를 마련하도록 요청
- ② 개인정보 목적 외 이용 및 제3자 제공 대장 기록·관리
- ③ 이용 또는 제공의 법적 근거, 목적 및 범위 등에 관하여 필요한 사항을 30일 이내, 관보 게재 또는 10일 이상 인터넷 홈페이지에 게재

□ 개인정보 처리업무 위탁(법 제26조)

○ (개인정보의 위탁 문서화) 개인정보처리자는 개인정보의 처리업무를 위탁할 경우 반드시 문서(개인정보 처리 위탁 계약서)를 작성하여야 함

○ (위탁업무 의무 사항)

- 위탁 내용 및 수탁자를 정보주체가 언제든지 쉽게 확인할 수 있도록 홈페이지(개인정보 처리방침) 등에 공개
- 재화 또는 서비스를 홍보하거나 판매를 권유하는 업무를 위탁하는 경우 위탁업무의 내용과 수탁자를 정보주체에 대해 개별 통지 의무
 - ※ 서면, 전자우편, 팩스, 전화, 문자전송 또는 이에 상당하는 방법으로 통지
- 개인정보의 분실·도난·유출·변조 또는 훼손을 방지하기 위한 수탁자 교육, 처리현황 점검 등 개인정보의 안전한 처리에 대한 감독 실시

○ (손해배상책임) 수탁자도 개인정보처리자의 소속 직원으로 간주하여, 위탁 업무 관련 법 위반으로 발생한 손해배상책임은 수탁자 외 위탁자도 부담

□ 개인정보의 파기(법 제21조)

- (개인정보의 파기) 개인정보처리자는 보유기간 경과, 처리목적 달성 등 개인정보가 불필요하게 되었을 때 지체 없이(5일 이내) 개인정보를 파기해야 함
- (파기 방법) 파기 시에는 복구 또는 재생되지 않도록 원천 삭제 조치
 - ※ 출력물, 서면 등은 파쇄·소각, 전자파일 형태는 복원 불가능하도록 영구 삭제
 - ※ 물리적 디스크 파기 방식: 로우 레벨 포맷, 디가우징(degaussing), 물리적 파쇄방식

□ 민감정보 및 고유식별정보의 처리 제한(법 제23조, 제24조, 제24조의2)

- 민감정보 및 고유식별정보는 원칙적으로 처리가 금지됨

[표 1-4] 민감정보 및 고유식별정보

구분	대 상
민감정보	사상, 신념, 노동조합·정당의 가입 및 탈퇴, 정치적 견해, 건강, 성생활 등의 정보, 유전정보, 범죄경력(전과·수형기록 등)에 관한 정보, 개인의 신체적·생리적·행동적 특징에 관한 정보로서 특정 개인을 알아볼 목적으로 일정한 기술적 수단을 통해 생성한 정보, 인종이나 민족에 관한 정보
고유식별정보	주민등록번호, 운전면허번호, 여권번호, 외국인등록번호

- (민감정보, 고유식별정보 처리 허용기준)(주민등록번호는 제외)

1. 정보주체에게 별도의 동의를 받은 경우
2. 법령에서 구체적으로 민감정보·고유식별정보의 처리를 요구하거나 허용하는 경우

- (주민등록번호 처리의 제한)

- 주민등록번호는 반드시 법적 근거가 있어야 처리 가능
- 주민등록번호 처리 허용기준

1. 법률·대통령령·국회규칙·대법원규칙·헌법재판소규칙·중앙선거관리위원회규칙 및 감사원규칙에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우
2. 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 명백히 필요하다고 인정되는 경우
3. 위의 사항에 준하여 처리가 불가피한 경우로서 보호위원회가 고시로 정하는 경우

- (고유식별정보 처리 의무사항)

- 고유식별정보의 분실, 도난, 변조, 훼손 방지를 위해 암호화 등 안전성 확보에 필요한 조치의무
- ※ 개인정보처리자가 처리하는 주민등록번호가 분실·도난·유출·변조 또는 훼손된 경우에는 5억원 이하의 과징금을 부과·징수할 수 있음. 다만, 주민등록번호가 분실·도난·유출·변조 또는 훼손되지 아니하도록 개인정보처리자가 안전성 확보에 필요한 조치를 다한 경우에는 예외

3 개인정보의 안전한 관리 조치

□ 개인정보 안전성 확보조치 기준(법 제29조, 시행령 제30조)

[표 1-5] 개인정보 안전성 확보조치 기준 요약

항목	준수내용
내부 관리계획 수립 및 시행	✓ 개인정보 보호책임자의 지정, 개인정보 보호책임자 및 개인정보취급자의 역할 및 책임, 안전성 확보조치, 개인정보취급자 교육, 수탁자 관리·감독 등 ✓ 개인정보처리자는 내부 관리계획 수립한 후, 전 직원에게 알려 준수하도록 함 ✓ 중요한 사항이 변경되는 경우 즉시 내부 관리계획을 수정하여 시행하고, 그 이력을 관리
접근권한의 관리	✓ 개인정보처리시스템 접근권한은 업무수행에 필요한 최소한의 범위로 차등 부여, 취급자별 계정 발급, 접근권한의 변경 또는 말소내역기록·보관, 사용자 계정관리 등 ✓ 접근권한 부여기록을 최소 3년간 보관 ✓ 홈페이지 관리자 페이지는 외부 인터넷에 공개 및 접속되지 않도록 조치
비밀번호 관리	✓ 개인정보취급자 또는 정보주체를 위해 안전한 비밀번호의 설정·이행을 위한 비밀번호 작성규칙을 수립하여 적용 ✓ 문자, 숫자, 특수문자 등을 조합하여 구성, 비밀번호의 주기적 변경
접근통제 시스템 설치 및 운영	✓ 방화벽 등 접근통제시스템 설치·운영, 공개된 무선망 이용 시 보호조치 ✓ 고유식별정보 수집 홈페이지 취약점 점검 1회/년 이상 ✓ 모바일 기기 보호조치, 외부에서 접속 시 VPN등 안전한 접속수단(예:공인인증서) 사용
개인정보의 암호화	✓ 암호화대상: 고유식별정보, 비밀번호, 바이오정보 ✓ 암호화기준 - (전송 시) 정보통신망 송수신 등의 경우 암호화 - (저장 시) ① 비밀번호 및 바이오정보 암호화(비밀번호 일방향 암호화) ② 고유식별정보는 인터넷구간, DMZ구간 저장 시 암호화하고 내부망 저장 시 위험도 분석에 따라 암호화 적용여부, 적용범위 결정 ✓ 주민등록번호를 저장 시, 영향평가나 위험도 분석의 결과에 관계없이 반드시 암호화를 적용해야 함
접속기록의 보관 및 위·변조 방지	✓ 개인정보처리시스템 접속기록의 안전한 보관, 정기적 점검 필요 ✓ 최소 1년 이상 보관, 월 1회 이상 점검 ✓ 접속자 ID, 접속일시, 접속자 정보, 수행업무, 처리한 정보주체 정보
보안프로그램 설치 및 운영	✓ 백신프로그램의 자동 업데이트 기능 사용 및 일1회 이상 최신 업데이트 실시 ✓ 응용프로그램 및 운영체제 보안업데이트 실시
물리적 접근방지	✓ 물리적 보관장소 출입통제, 보조저장매체 반·출입 통제 절차 등 ✓ 개인정보가 포함된 서류나 이동형 하드디스크, USB메모리, Flash메모리, CD, DVD 등의 보조기억매체는 금고 또는 잠금장치가 있는 캐비닛 등에 안전하게 보관
개인정보의 파기	✓ 개인정보 완전파기(완전파기가 어려울 경우 부분파기)
미조치에 따른 유출 시	매출액의 3% 또는 20억 이내의 과징금
보호조치 미비	3천만원 이하 과태료